

# INFORME DE AUDITORÍA DE SEGURIDAD



- Autor: Marcos Cabello Vargas
- Fecha : 16/09/2025
- Entorno: Windows 10

# OBJETIVO Y ALCANCE

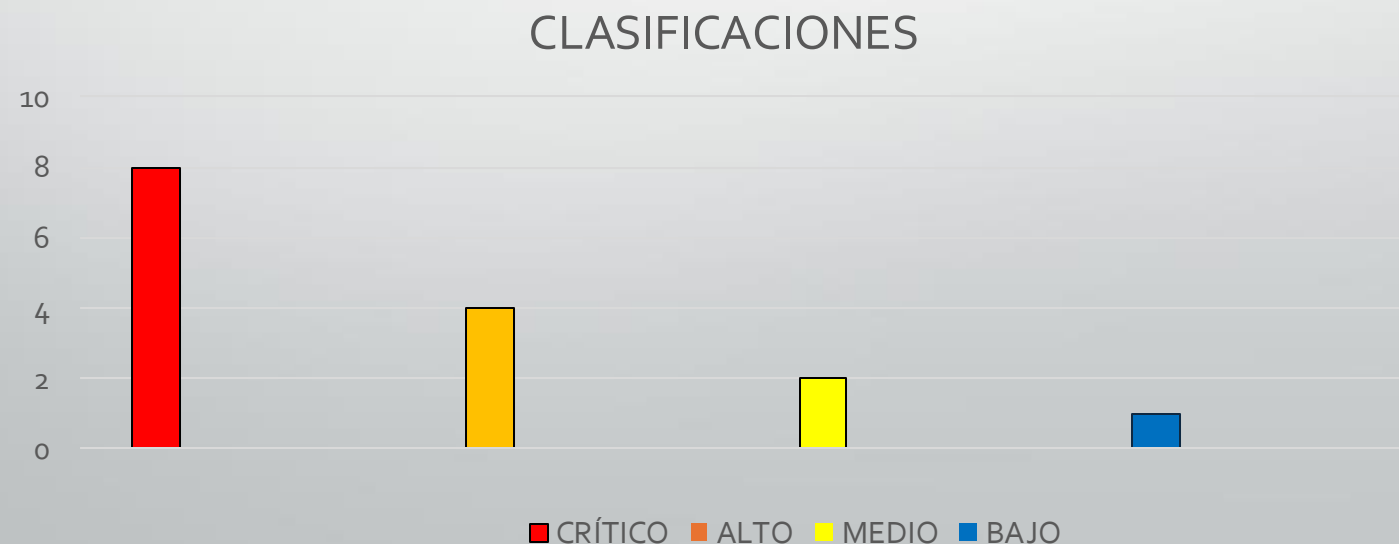
- El objetivo de este análisis es evaluar el estado de seguridad del sistema **Windows 10** identificado en la red interna , con el fin de identificar y clasificar las vulnerabilidades presentes en sus servicios y configuración, y proporcionar recomendaciones para su mitigación.

# SUMARIO EJECUTIVO

- Durante la auditoría de seguridad realizada sobre el sistema operativo **Windows 10**, se identificaron múltiples servicios expuestos con distintos niveles de riesgo. Entre las vulnerabilidades de mayor criticidad se encuentran:
- Un **servidor FTP (FileZilla beta)** accesible sin cifrado.
- El servicio **SMBv2 activo en el puerto 445**, asociado a vulnerabilidades históricas críticas.
- El **protocolo RDP expuesto sin medidas adicionales de protección** como NLA.
- Un servicio **VNC accesible públicamente**, potencialmente sin cifrado ni autenticación fuerte.
- Además, se detectaron otros servicios de riesgo medio y bajo como **puertos MSRPC expuestos, NetBIOS habilitado**, y un **servidor web IIS** sin información clara sobre su configuración de seguridad.
- La presencia simultánea de estos servicios abiertos incrementa la superficie de ataque del sistema y puede ser aprovechada por un atacante tanto en redes internas como externas.

# CLASIFICACIÓN DE VULNERABILIDADES

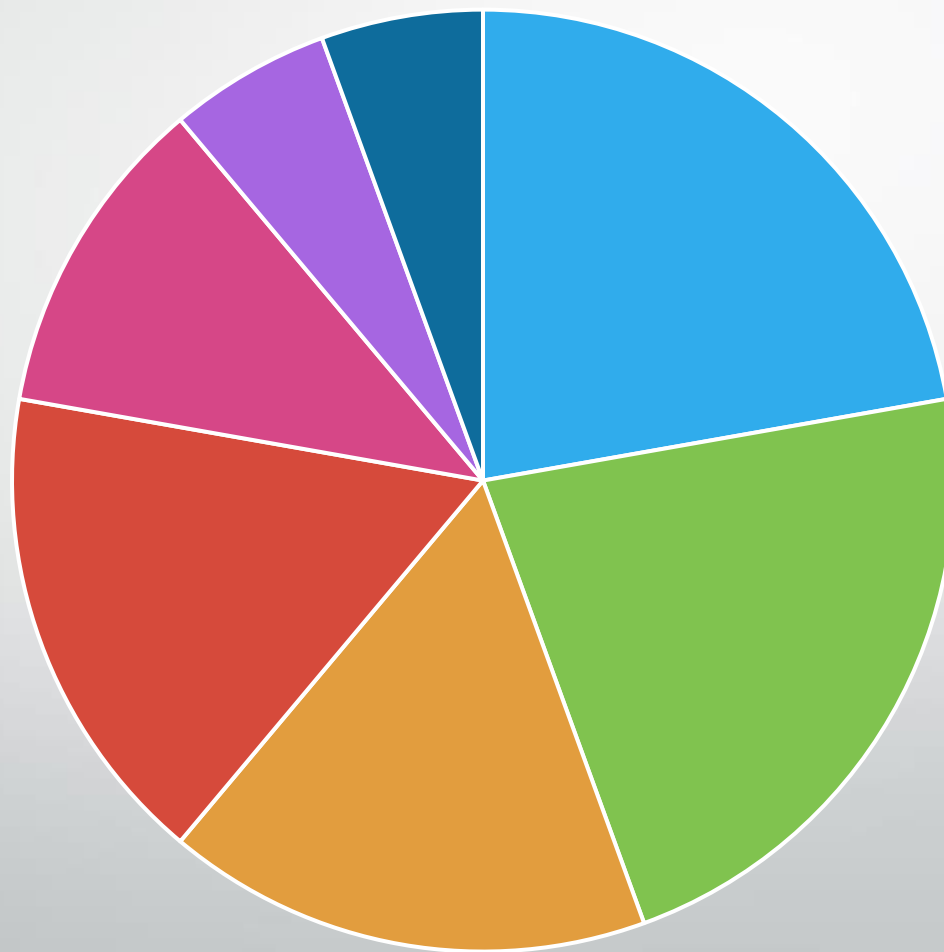
- Las vulnerabilidades se clasifican conforme a los siguientes criterios:
  - **Crítico:** Permite la toma de control total del sistema o ejecución remota de código.
  - **Alto:** Permite acceso a información sensible, credenciales o enumeración de usuarios clave.
  - **Medio:** Expone información técnica no sensible, configuraciones inseguras o servicios innecesarios.
  - **Bajo:** Corresponde a configuraciones por defecto, servicios con información mínima o métodos que, por sí solos, no representan riesgo directo, pero podrían ser aprovechados en combinación con otras debilidades.



| Nivel   | Puerto     | Servicio        | Descripción                                                                                                                                                 | CVE                          | Recomendación                                                                                                                         |
|---------|------------|-----------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|---------------------------------------------------------------------------------------------------------------------------------------|
| Crítico | 445        | SMBv1           | El protocolo SMBv1 está habilitado. Esto permite ataques como EternalBlue (ejecución remota de código), propagación de ransomware y otros exploits críticos | CVE-2017-0144                | Deshabilitar SMBv1, aplicar el parche de seguridad MS17-010, actualizar el sistema y restringir el acceso a SMB desde redes externas. |
| Crítico | 21         | FTP(FileZilla)  | FileZilla 0.9.60 beta permite conexiones sin cifrado y puede aceptar acceso anónimo o sin control. Vulnerable a exposición o acceso no autorizado.          | CVE-2020-0796, CVE-2017-0144 | Aplicar parches, deshabilitar SMBv1, restringir por firewall.                                                                         |
| Alto    | 3389       | RDP             | Puerto RDP expuesto públicamente sin verificación adicional. Riesgo alto de fuerza bruta o explotación (ej: BlueKeep).                                      | CVE-2019-0708                | Habilitar NLA, restringir por IP, aplicar MFA y parches.                                                                              |
| Alto    | 5800/5900  | VNC (TightVNC)  | VNC sin cifrado o puede exponer el escritorio remoto a interceptación o acceso remoto no autorizado.                                                        | CVE-2019-15681               | Habilitar autenticación fuerte, cifrado o restringir uso de VNC.                                                                      |
| Medio   | 135, 496xx | MSRPC           | Servicios RPC abiertos permiten enumeración e interacción con componentes internos (DCOM, spooler).                                                         | CVE-2021-1675                | Restringir acceso a puertos, parchear sistema, aplicar segmentación.                                                                  |
| Bajo    | 139        | NetBIOS         | Puerto 139 abierto puede permitir enumeración de usuarios, equipos y recursos en red local.                                                                 |                              | Deshabilitar si no se utiliza. Filtrar tráfico interno.                                                                               |
| Bajo    | 80         | HTTP (IIS 10.0) | HTTP activo. Si se permiten métodos como TRACE o versiones inseguras, puede habilitar vectores como XST.                                                    | CVE-2004-2320                |                                                                                                                                       |

# GRÁFICO DE RIESGOS

Nivel de Riesgo



■ Puerto 445 ■ Puerto 21 ■ Puerto 3389 ■ Puerto 5800/5900 ■ Puerto 135/496xx ■ Puerto 80 ■ Puerto 139

# RECOMENDACIONES

- **Recomendaciones generales para la máquina Windows 10 auditada**
  - **Actualizar o deshabilitar el servicio FTP (FileZilla)** si no es necesario, o configurar autenticación segura y cifrado (FTPS).
  - **Aplicar todos los parches de seguridad acumulativos de Windows 10**, especialmente relacionados con SMBv2 y RDP.
  - **Restringir el acceso remoto al servicio RDP (puerto 3389)** mediante firewall, listas blancas de IPs y activación de NLA.
  - **Configurar o deshabilitar el servicio VNC (puertos 5800/5900)** si no se utiliza, y aplicar autenticación fuerte y cifrado si se mantiene.
  - **Cerrar puertos MSRPC (135 y 496xx)** si no se requieren. Limitar su uso a entornos internos y con privilegios mínimos.
  - **Deshabilitar NetBIOS si no es imprescindible**. En caso contrario, filtrar el acceso solo para redes internas autorizadas.
  - **Auditar la configuración del servidor web IIS (puerto 80)**. Desactivar métodos inseguros como TRACE y añadir cabeceras de seguridad.
  - **Realizar un seguimiento continuo del sistema** mediante soluciones EDR o SIEM, especialmente si expone servicios remotos.

# EVIDENCIAS

- A continuación, se presentan las capturas de pantalla obtenidas durante el análisis de seguridad del host auditado. Estas evidencias respaldan las vulnerabilidades descritas en el informe principal, permitiendo validar los puertos abiertos, los servicios expuestos y configuraciones detectadas que representan un riesgo para el sistema.



# EVIDENCIA N° 1 – FTP (FileZilla 0.9.60 beta)

- **Puerto: 21**
- **Nivel de Riesgo: Crítico**
- **Recomendación:**
  - Deshabilitar SMBv1, aplicar el parche de seguridad MS17-010, actualizar el sistema y restringir el acceso a SMB desde redes externas.
- **Descripción:**
  - Se observa el servicio FTP activo (FileZilla Server 0.9.60 beta). Las versiones beta suelen tener vulnerabilidades sin parches estables. Si se permite autenticación débil o anónima, puede facilitar accesos no autorizados o fuga de información.

```
Connected to 192.168.88.141.  
220-FileZilla Server 0.9.60 beta  
220-written by Tim Kosse (tim.kosse@filezilla-project.org)  
220 Please visit https://filezilla-project.org/  
Name (192.168.88.141:kali):
```

# EVIDENCIA N° 2 – SMBv1 habilitado

- Puerto: 445
- Nivel de Riesgo: Crítico
- Recomendación:
  - Aplicar parches, deshabilitar SMBv1, restringir por firewall.
- Descripción:
  - Se ha verificado que el protocolo **SMBv1** está habilitado en la máquina objetivo 192.168.88.141. Esto supone una vulnerabilidad crítica ampliamente documentada, explotada por malware como WannaCry y EternalBlue.

```
Starting Nmap 7.95 ( https://nmap.org ) at 2025-07-16 08:18 EDT
Nmap scan report for 192.168.88.141
Host is up (0.00018s latency).

PORT      STATE SERVICE
445/tcp   open  microsoft-ds
MAC Address: 00:0C:29:D0:95:A5 (VMware)

Host script results:
|_ smb-protocols:
|   dialects:
|       NT LM 0.12 (SMBv1) [dangerous, but default]
|       2:0:2
|       2:1:0
|       3:0:0
|       3:0:2
|_      3:1:1

Nmap done: 1 IP address (1 host up) scanned in 17.81 seconds
```

# EVIDENCIA N° 3 – Servicio RDP expuesto

- **Puerto:** 3389
- **Nivel de Riesgo:** Alto
- **Recomendación:**
  - Habilitar NLA, restringir por IP, aplicar MFA y parches.
- **Descripción:**
  - El servicio de escritorio remoto (RDP) está disponible sin información de protección adicional (como NLA). Esto puede ser explotado mediante fuerza bruta, BlueKeep u otras técnicas de acceso remoto.

```
Host is up (0.00023s latency).  
  
PORT      STATE SERVICE  
3389/tcp  open  ms-wbt-server  
| rdp-ntlm-info:  
|   Target_Name: TSS  
|   NetBIOS_Domain_Name: TSS  
|   NetBIOS_Computer_Name: PC-POCEZ  
|   DNS_Domain_Name: TSS.local  
|   DNS_Computer_Name: PC-pocetz.TSS.local  
|   DNS_Tree_Name: TSS.local  
|   Product_Version: 10.0.18362  
|_ System_Time: 2025-07-17T18:04:41+00:00  
MAC Address: 00:0C:29:D0:95:A5 (VMware)
```

## EVIDENCIA N° 4 – VNC activo (TightVNC)

- **Puerto:** 5800/5900
- **Nivel de Riesgo:** Alto
- **Recomendación:**
  - Habilitar autenticación fuerte, cifrado o restringir uso de VNC.
- **Descripción:**
  - El escaneo revela un servidor VNC (TightVNC) accesible públicamente. Este tipo de servicio no usa cifrado por defecto y puede ser comprometido si no tiene autenticación fuerte.

```
Connected to RFB server, using protocol version 3.8  
Enabling TightVNC protocol extensions  
Performing standard VNC authentication
```

# EVIDENCIA N° 5 – MSRPC abierto

- Puerto: 135,496xx
- Nivel de Riesgo: Medio
- Recomendación:
  - Restringir acceso a puertos, parchear sistema, aplicar segmentación.
- Descripción:
  - Múltiples puertos asociados a Microsoft RPC están abiertos. Esto permite enumerar servicios internos y puede facilitar ataques como PrintNightmare si no está actualizado.

```
230 Logged on
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||64892|)
150 Opening data channel for directory listing of "/"
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 $Recycle.Bin
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 $WINDOWS.BT
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 $WinREAgent
drwxr-xr-x 1 ftp ftp          0 Jan 05 2021 aeb996daea86d7b5f4e00e23226ee5
drwxr-xr-x 1 ftp ftp          0 Apr 30 2020 Archivos de programa
-r--r--r-- 1 ftp ftp    395268 Jul 10 2015 bootmgr
-r--r--r-- 1 ftp ftp          1 Jul 10 2015 BOOTNXT
drwxr-xr-x 1 ftp ftp          0 Mar 11 2021 Dev-Cpp
drwxr-xr-x 1 ftp ftp          0 Jul 10 2015 Documents and Settings
-r--r--r-- 1 ftp ftp    198670 Jan 12 2021 gpresult.html
drwxr-xr-x 1 ftp ftp          0 Jan 12 2021 inetpub
-r--r--r-- 1 ftp ftp    1006632960 Jul 16 14:02 pagefile.sys
drwxr-xr-x 1 ftp ftp          0 Mar 11 2021 PerfLogs
drwxr-xr-x 1 ftp ftp          0 Jul 16 14:02 Program Files
drwxr-xr-x 1 ftp ftp          0 Mar 23 2021 Program Files (x86)
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 ProgramData
drwxr-xr-x 1 ftp ftp          0 Apr 30 2020 Python27
drwxr-xr-x 1 ftp ftp          0 Jun 09 2025 Recovery
-r--r--r-- 1 ftp ftp    268435456 Jul 16 14:02 swapfile.sys
drwxr-xr-x 1 ftp ftp          0 Jan 12 2021 System Volume Information
drwxr-xr-x 1 ftp ftp          0 Mar 14 2021 Users
```

# EVIDENCIA N° 6 – NetBIOS expuesto

- **Puerto: 139**
- **Nivel de Riesgo: Bajo**
- **Recomendación:**
  - Deshabilitar si no se utiliza. Filtrar tráfico interno.
- **Descripción:**
  - El puerto 139 permite comunicación NetBIOS, lo que facilita la enumeración de recursos compartidos y usuarios del sistema. Es un vector común de reconocimiento en ataques internos.

```
( Target Information )
Target ..... 192.168.88.141
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

( Enumerating Workgroup/Domain on 192.168.88.141 )

[+] Got domain/workgroup name: TSS

( Nbtstat Information for 192.168.88.141 )

Looking up status of 192.168.88.141
TSS <00> - <GROUP> M <ACTIVE> Domain/Workgroup Name
PC-POCEZ <00> - M <ACTIVE> Workstation Service
PC-POCEZ <20> - M <ACTIVE> File Server Service
TSS <1e> - <GROUP> M <ACTIVE> Browser Service Elections
TSS <1d> - M <ACTIVE> Master Browser
.._MSBROWSE_. <01> - <GROUP> M <ACTIVE> Master Browser

MAC Address = 00-0C-29-D0-95-A5
```



# EVIDENCIA N° 7 – HTTP activo (IIS 10.0)

- **Puerto: 80**
- **Nivel de Riesgo: Bajo**
- **Descripción:**
  - El servidor web IIS 10.0 está activo. Si no se protegen los métodos HTTP o se deshabilita TRACE, podría facilitar ataques como XST o exposición innecesaria de información..

```
+ Target IP:      192.168.88.141
+ Target Hostname: 192.168.88.141
+ Target Port:    80
+ Start Time:     2025-07-17 14:28:54 (GMT-4)

+ Server: Microsoft-IIS/10.0
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ 8102 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time:       2025-07-17 14:29:05 (GMT-4) (11 seconds)

+ 1 host(s) tested
```

# CONCLUSIÓN

- Durante la auditoría realizada al sistema Windows 10 , se detectó una exposición significativa de servicios críticos como FTP, SMBv2, RDP y VNC. Algunos de estos presentan vulnerabilidades conocidas o configuraciones inseguras que podrían ser explotadas para comprometer la confidencialidad, integridad o disponibilidad del sistema.
- También se identificaron servicios internos (MSRPC, NetBIOS) que, aunque no representan un riesgo crítico por sí solos, amplían la superficie de ataque si no se segmentan y protegen adecuadamente.
- Se recomienda implementar las medidas correctivas indicadas, priorizar la actualización del sistema y realizar una revisión periódica de la configuración de los servicios expuestos. La reducción de la superficie de ataque es esencial para mantener una postura de seguridad robusta frente a amenazas actuales.